

Footprinting & Reconnaissance

- What is footprinting and which goals does it achieve? Describe the basic steps that should be performed for a thorough footprinting analysis.
- What is footprinting on the defensive side useful for? Describe the attack steps to build a near-complete profile of an organization's security posture.

Scanning & Host Discovery

- What are ping sweeps? Describe at least two host discovery techniques and at least one tool used to perform host discovery.
- Describe at least one technique to determine which services are running or listening on a remote host. Discuss the pros and cons, and which tools you may use in practice (addressing specific protocols like TCP Connect, SYN, FIN, Xmas Tree, NULL, ACK, Windows, RPC, and UDP scans).

Enumeration

- Discuss the differences between scanning and enumeration. Describe at least one enumeration technique (such as Basic Banner Grabbing).
- Explain Simple Network Management Protocol (SNMP) enumeration. Which community strings/accounts do you need, how can Windows users be enumerated via this method, and what are the specific countermeasures?
- Detail the techniques and tools utilized to perform Active Directory enumeration (including ldp.exe, LUMA, Jxplorer, and ldapenum), along with the prerequisites and countermeasures.

Windows Security, Hacking & Post-Exploitation

- The Administrator account of a Windows server has been compromised. Host software cannot be re-installed for business reasons. With these assumptions, how do you plan and implement post-exploit activities for the host recovery? In particular, list the areas of the system on which to intervene to restore the host's security. Discuss in detail at least one of these areas of intervention, listing the activities to be carried out, the tools, and the line commands to be used (such as reg.exe, taskkill, and netstat).
- Explain what steps an attacker should take to cover their tracks after successfully gaining administrator privileges on a Windows system in order to

avoid detection. How can attackers hide their files in the system (addressing tools like auditpol, event log clearing utilities like ELSave, the attrib command, and Alternate Data Streams)?

- Where are rootkits generally placed in Windows systems, which tools are used to deploy or detect them, and what are the specific countermeasures?
- What are the three main network password exchange protocols used in Windows systems? Describe the pass-the-hash and pass-the-ticket attacks along with their corresponding countermeasures (detailing protocols like LM, NTLM, Kerberos, and tools like WCE or Cain).
- Describe at least three Windows security features available with Windows 2000 and above (such as BitLocker/EFS, Windows Resource Protection, Integrity Levels/UAC/PMIE, DEP, or EMET). Are there published attacks (such as cold boot attacks or hash-reset tools like chntpw) that bypass these features? Note that the presentations of Windows Firewall and Automated Updates will not be evaluated.

Advanced Persistent Threats (APTs) & Incident Response

- Describe the six main steps that constitute an APT attack and indicate for each one the artifacts or traces that are usually left in the victim system.
- When detecting an APT attack, the tools used by the administrators may be compromised so as to return false information. Describe at least 8 of the 22 recommended filesystem and registry checks used to identify Indicators of Compromise (IoCs).
- An ongoing APT attack has compromised one of the Windows servers. With this assumption, how do you plan and implement the forensic methodology, the tools, and the command lines to be used to analyze the 'suspicious' host? Discuss the order of volatility (RFC 3227) and specialized volatile data collection frameworks (such as FTK Imager, Volatility, Process Explorer, VMMap, netstat -o, and prefetch listing).

Remote Connectivity & VoIP Hacking

- Explain the function of War Dialers and the specific phases involved in Dial-up hacking (Footprinting, Scanning, and Enumeration domains). What tools (such as WarVOX) and operational countermeasures apply?
- Describe at least three attacks against a VoIP network. Include in your description the activities to carry out, the tools, and the command lines to be

used (such as SIP Scanning via SiVuS/SIPVicious, Pillaging TFTP configuration files, and SIP invite floods via inviteflood). What are the possible countermeasures for each of these attacks? Note that user enumeration should be excluded from this specific discussion.

- How does user enumeration occur on open-source SIP gateways (such as Asterisk REGISTER or SIP Express Router OPTIONS)? Explain the specific differences between valid and invalid responses (such as Unauthorized vs. Forbidden or OK vs. Not Found) used to map out extension networks.
- Discuss Citrix Access Gateway vulnerabilities and deployment errors (Remote Desktop, Bulk Commercial Application/COTS, Custom applications). How do attackers exploit published applications to gain unauthorized shell access, and what are the countermeasures?

Wireless Security & Hacking

- Describe at least one method for attacking WPA Pre-Shared Key (WPA-PSK). Explain how an attacker captures the four-way handshake and launches offline brute-force attacks (detailing aircrack-ng, rainbow tables, or GPU cracking tools) along with countermeasures.
- Describe at least one method to attack WPA Enterprise. How do attackers identify EAP types (addressing LEAP cleartext vulnerabilities vs. EAP-TTLS/PEAP tunnel impersonation), and what are the server-side certificate validation countermeasures?
- Explain how wireless interface sniffing operates at Layer 2 (including FCC ID lookups and software-defined radios like WinRadio or USRP) to achieve symbol decoding.

Mobile Hacking

- Regarding hacking other Android devices, describe at least two (or three) methods to attack them (focusing on Remote Shell via WebKit floating-point exploits, rooting via Rage Against TheCage/RATC, URL-sourced malware side-loading, and Skype unencrypted data exposure). What are the possible countermeasures?
- Explain the concept of Capability Leaks on Android devices (explicit vs. implicit entry points, shareUserId attributes), detailing how untrusted applications abuse preloaded system permissions without explicit user authorization, along with countermeasures.

- Detail the mechanics of URL-Sourced Malware side-loading (addressing banking Trojans like ZeuS and SpyEye intercepting SMS second-factor PINs) and how to configure Android's "Unknown Sources" security feature to block it.
- Can Linux security tools be ported to Android? Explain how a cross-compiler is used to port open-source tools (such as BusyBox, tcpdump, and nmap) from X86 architectures to run directly at the ARM Linux kernel level. Provide the console commands to push and install them via ADB.
- Describe four Android security measures available with Android version 3.0 and above (including physical security, device locking/Face Unlock, disabling unknown sources, security software installations, full storage area encryption, and firmware upgrades) and discuss whether there are published exploits that successfully bypass them.
- From recent past papers, identify and explain mobile-specific security vectors, explicitly detailing remote data stealing, URL-sourced malware, carrier IQ tracking, and the HTC logger vulnerability.

Hardware Hacking

- Explain what the Advanced Technology Attachment security mechanism (ATA security) is. Describe the specific step-by-step hot-swap attack workflow used to bypass ATA password locks using a secondary unlocked drive, and how to defend against it using full-disk encryption.
- Describe at least two techniques for hacking physical hardware devices. Focus on attacks against devices that store sensitive information (such as MagStripe card cloning/Magnetic Stripe Card Explorer software vs. RFID card cloning/proxmark3/USRP systems utilizing challenge-response protocols).
- Explain firmware reversing concepts, detailing the utilization of specialized tools like hex editors (010 Editor), disassemblers (IDA Pro), and shell commands (`strings` , `mount -o loop -t cramfs` , and `find`) to extract hardcoded credentials or encryption keys.
- Describe the USB U3 Hack technique utilizing a secondary partition on flash drives. Detail the attack steps to execute scripts via autorun to copy local password hashes using tools like fgdump, along with countermeasures.